Explaining URL Phishing Detection by Glass Box Models

Sangeeta Mittal
Jaypee Institute of Information Technology, Noida
sangeeta.mittal@jiit.ac.in

ABSTRACT

Phishing is one of the successful cyberattack that targets unsuspecting users to make them divulge personal sensitive information. Uniform Resource Locator (URL) phishing particularly involves distributing address strings of phishing websites via various vectors like email, websites and phone SMSes. Feature engineering of these URLs reveals that extracting meaningful statistical information and training Machine Learning (ML)based models for identifying whether a URL is legitimate is an effective automated means of protecting users from these attacks. In this work, a case of Explainable AI (XAI) has been made to provide insights into how algorithms make predictions, enabling humans to understand and evaluate why the URL under question is not secure to visit. Various examples have been illustrated to visualize the explanations. The work can act as a basis for generating counterfactuals to minimize the unintentional composition of a URL as phishing.

CCS CONCEPTS

• **Security and privacy - Software and application security**; • **Web application security**; • **Security and privacy**; • **Human and societal aspects of security and privacy**;

KEYWORDS

Phishing URL Attacks, Web Security, Explainable AI, Decision Tree, Logistic Regression

ACM Reference Format:
Sangeeta Mittal. 2023. Explaining URL Phishing Detection by Glass Box Models. In *2023 Fifteenth International Conference on Contemporary Computing (IC3-2023) (IC3 2023), August 03–05, 2023, Noida, India.* ACM, New York, NY, USA, 8 pages. https://doi.org/10.1145/3607947.3608059

1 INTRODUCTION

URL phishing is a type of cyberattack that aims to trick users into giving away their sensitive information such as passwords, credit card numbers, or personal information by leading them to fake websites that appear to be legitimate. In this type of attack, scammers create fake web pages that resemble those of trusted sites, and they send emails or SMS that contain a link to these pages. When users click on the link, they are taken to the fake site, where they may unwittingly enter their personal information. The scammers then use this information for identity theft, financial fraud, or other malicious purposes. It is important to always verify the legitimacy of a website before entering any sensitive information. According to security pioneer Kaspersky, its anti-phishing system confronted about half a billion phishing attempts in 2022 which was double the time than in 2021 [1]. This shows that although the attack is not technologically sophisticated it has survived all the security solutions because of successful social engineering means [2]. Instant messengers, online gaming platforms, cryptocurrency platforms and delivery services have been the most commonly used baits for phishing. Quite a few researchers have proposed to use machine learning to detect phishing URLs. Most of the approaches either extract features from either the content of the websites or abnormalities in the URL string. It is obvious that practically, the latter approach is more useful due its speed of detection without visiting the website [3]. Thus, in this work string-based features have been used mainly along with Internet reputation-based information.

Machine learning can be used for URL phishing detection by training algorithms to extract predefined features in URLs that are commonly associated with phishing attacks. Experts can reason on which of the features can be extracted and are also distinguishable for phishing and normal URLs. The process of defining features is manual and is guided partially by visually looking at the available datasets. Once these features are supplied to machine learning algorithms they use patterns in the data to develop a mathematical model that can be used to make predictions on new data. However, these algorithms are highly complex and difficult to interpret, making it challenging to understand why they produce certain results. Machine learning models can be classified as either glass box or black box models, depending on the level of transparency and interpretability they provide. Glass box models, also known as interpretable models, are models that can be easily understood and interpreted by humans. These models use simple, transparent algorithms such as decision trees, linear regression, or logistic regression, which can be easily visualized and explained.

Explainable AI (XAI) can help to provide clear and understandable explanations for AI decisions, increasing transparency and trust in the system. In phishing URL detection, it can be very helpful to determine why a URL has been classified as a suspicious link [4].

In this work, we generate explanations of prediction decisions made by the glass box models random forest and logistic regression. These explanations can be used to identify the most relevant feature in every prediction. The increased transparency will enhance the confidence of the user in the system. By providing explanations for why a URL was identified as a phishing URL, XAI can help users to provide feedback on the accuracy of the system and identify areas for improvement.

The paper is organized as follows. Section 2 describes the related work done in the chosen domain. Section 3 describes the implementation of two glass box models and demonstration of their

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
IC3 2023, August 03–05, 2023, Noida, India
© 2023 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 979-8-4007-0022-4/23/08…$15.00
https://doi.org/10.1145/3607947.3608059

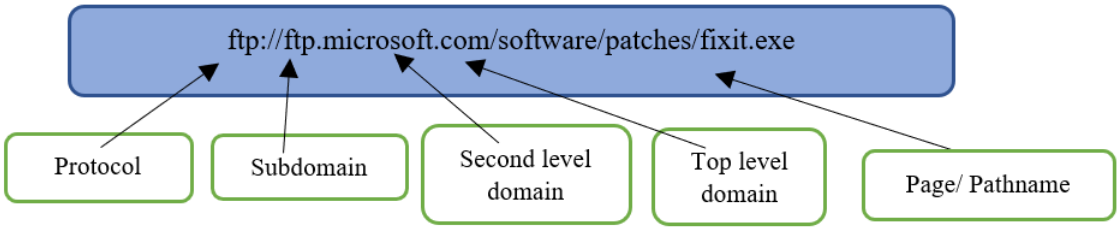

Figure 1: Components of a URL

interpretations. Section 4 discusses the implementation and results. The paper is concluded in Section 5.

2 RELATED WORK

The URLs are well defined strings and are composed of seven parts namely protocol, sub-domain name, second level domain, top-level domain, and path of particular resource being fetched. An example of URL and its components is shown in Figure 1.

Althobaiti 2021 in [5] made some observations about phishing URL detection. Companies normally use domain names that match their brand name and some defensive domains to protect their customers from both typing errors and attackers. Moreover, companies may have entirely different domain names due to different product lines or acquisitions. For example, facebook and Instagram both belong to same company. Thus, it is not trivial to just look at a domain name and associate it with a particular organization as real world domain names don't always follow the same set of rules. Due to cloud based hosting , many websites with malicious content have a trusted URL. Moreover, shortened and redirected URLs cannot be obtained for checking. They hardcoded a set of facts differentiating malicious URLs from benign ones and some heuristics to present a report explaining why the URL maybe considered as malicious. Authors in [6] used lexical and host-based features to detect URLs obtained from phishtank. Severe, Moderate, and Benign categories were assigned to URLs based on the probability of being a phishing or normal website according to the features chosen. Jeeva and Raj Singh in [7] defined 14 heuristic features and applied apriori and predictive apriori algorithm. Authors claim that during testing, 93 % of the phishing URL were correctly detected. [8] suggested that IP Address , Redirection of page using "//" , Adding Prefix or Suffix Separated by (-) to the Domain, Sub domain and multi-sub domain, URLs having @ symbol, using different functions in the URL to submit information, Page Rank and Google Index are important indicators of a phishing URL. However, features like page rank and google index are time consuming to find. Authors in [9] made use of same features as used in this work and used rule based induction from different tools JRip and PART. They consolidated rules created by both the tools to get a final set of rules. Authors reported about 94 – 99% accuracy on different datasets using their approach. KL divergence between a URL & English words along with entropy of each URL have been found to be two most important features in [10]. Best accuracy reported on these custom defined features is 84%. This can be improved if the model can be explained. In [11] features like no.of token in a domain, words separated by special characters, number of top level domains, url length, no. of dots in URL, no. of delimiter in a domain, no. of delimiter in the path, length of longest token in the path and domain length have been extracted and used to train the models. They applied ML algorithms and achieved 99% accuracy. Authors in [12] chose their own features and obtained highest accuracy of 86% with a light gradient boosting machine (GBM) followed by 85% in logistic regression and random forest. Few researchers have used explainable AI to explain the anti-phishing predictions. [13] explained and detected URL Phishing using Local Interpretable Model-Agnostic Explanations (LIME) and Explainable Boosting Machines (EBM). In [14], the authors implemented ensemble learning model comprises two levels - level 0 consists of LightGBM, Gradient boost, XGBoost, and random forest, and level 1 consists of a random forest model. Later, Explainable AI (XAI) was used to explain the working of the model and demystify the black-box nature of machine learning algorithms. Albakry and Vaniea in [15] proposed the use of XAI for explaining the severity of warnings generated by safe browsing features of the browser to help the user decide to either proceed with the downloading of the website or abort it. However, authors didn't verify or implement any of these techniques.

3 MACHINE LEARNING BASED PHISHING URL DETECTION AND EXPLAINABLE AI

As concluded from literature review section, supervised machine learning when used with suitable features, is an effective technique to automatically classify the URLs as phishing and warn the users as they are about to visit these URLs. In this work, the dataset available at [16] has been utilized to train two machine learning models namely decision trees (DT) and logistic regression (LR). The dataset has 11055 labelled instances of URLs represented as a vector of 30 features based on HTML tags, URL statistics and Internet based reputation. As the number of instances of phishing URLs is 4897 and that of Normal sites is 6157, the dataset is suitable for ML training. The names and values of some of these features are given in Table 1.

Explainable models – Glass box models are interpretable due to their structure. In this work, two such models namely Logistic regression (LR) and Decision Trees (DT) have been considered to evaluate their interpretability. There are two types of explanations that can be produced. The first type is a global explanation, which examines the general behavior of the model and identifies the most significant features that influence its predictions through global feature importance. The second type is local explanations, which

Table 1: Partial List of Features Used for Training the Glass box Models

Type of Feature	Feature Name	Feature Description
Address Bar based Features	Having an IP address	IF contains IP Address then Phishing else Legitimate
	Having a long URL	IF length of URL < 54 then Normal else if >54 and <75 then Suspicious else Phishing
Abnormal Requests Based Features	Request_URL	IF percent of requested URLs <22 then Normal else if ≥22 and <61 then Suspicious else Phishing
	Abnormal URL anchor	IF percent of abnormal URL of Anchor <31 then Normal else if ≥31% And ≤67 then Suspicious else Phishing
HTML and JavaScript based Features	Redirect	IF number of redirected Page ≤1 then Normal else if ≥2 And<4 then Suspicious else Phishing
	On mouseover	IF onMouseOver Status Bar changes then Phishing else Normal
Domain Features	Age of domain	IF Age of Domain≥6 months then Normal else Phishing
	DNS record	IF DNS Record not found then Phishing else Normal

Table 2: Performance of LR and DT Models in Phishing URL detection

	F1 Score	Accuracy
Logistic regression	94.7	94.8
Decision Trees	90.6	90.7

clarify an individual prediction and discover the features that are responsible for it through local feature importance. It has been illustrated here, as to how the changes to input features influence predictions by employing techniques like what-if analysis and explain a subset of predictions. Logistic regression is a model that estimates the probabilities of two possible outcomes in classification problems. It is an extension of the linear regression model and provides both classification and probability outputs. The logistic regression model yields a probability outcome between 0 and 1, which is a significant advantage over models that only offer the final classification. Understanding that a particular instance has a 99% probability for a particular class as opposed to 51% can make a substantial difference. Logistic regression models are limited in situations where the association between features and outcomes is nonlinear or where features interact with one another. In contrast, tree-based models divide the data into multiple subgroups based on specific cutoff values in the features. The average outcome of the training data in each leaf node is employed to forecast the outcome. The tree structure is advantageous in capturing the interactions between features in the data. The data is segregated into distinct groups, which are often easier to comprehend than points on a multi-dimensional hyperplane as seen in linear regression. The interpretation of tree structures is relatively straightforward. Additionally, the nodes and edges of the tree structure make for a natural visualization. Trees provide easy-to-understand explanations.

4 EXPLANATIONS OF THE PREDICTIONS

InterpretML python package that supports training interpretable glass box models has been used for implementation of the models [17]. Accuracy gives the percentage of correctly classified instances. The F1 Score is used to evaluate the performance of a binary classification model, which considers both precision and recall. It is the harmonic mean of precision and recall, with a value between 0 and 1. Table 2 shows the evaluation of the chosen glass box models. Decision trees are lesser accurate than logistic regression in classifying the URLs. The main limitation of the glass box models is that although they are interpretable by design but their accuracy is lower than black box models like neural networks [18].

Global decision-making visualizations given by logistic regression classifier as shown in Figure 2 (a) is two colored. The blue ones show the features that have negative coefficients and their high values lead to the decision of URL being a “Normal ” site while orange ones are those that have positive coefficients and thus when values of these features are high in a test instance than there are chances of that site being “Phishing” site. It can be seen from the visualizations of explanations that high values of features like (i) anchor tags in the website source have domain name other than the actual one, (ii) prefixes or suffixes are added to known URLs by using a dash symbol, (iii) the certificate of site is not found to be trusted, (iv) web traffic to the site has not been frequent historically (v) https word has been added to give a visual impression of site being safe (vi) too many popups asking for personal information (vii) link tags like <meta> ,script> <link> pointing to different domains (viii) sensitive information is being redirected to some personal email . On the other hand, high values of positive coefficients like (i) DNS record is authentic (ii) Standard port 80 is being used (iii) the page is indexed by Google (iv) website forwarding is not done more than once (v) The script that handles the input received at the server is in same domain and does some relevant action decide in suggesting that site is legitimate. Figure 2 (b) shows that the global

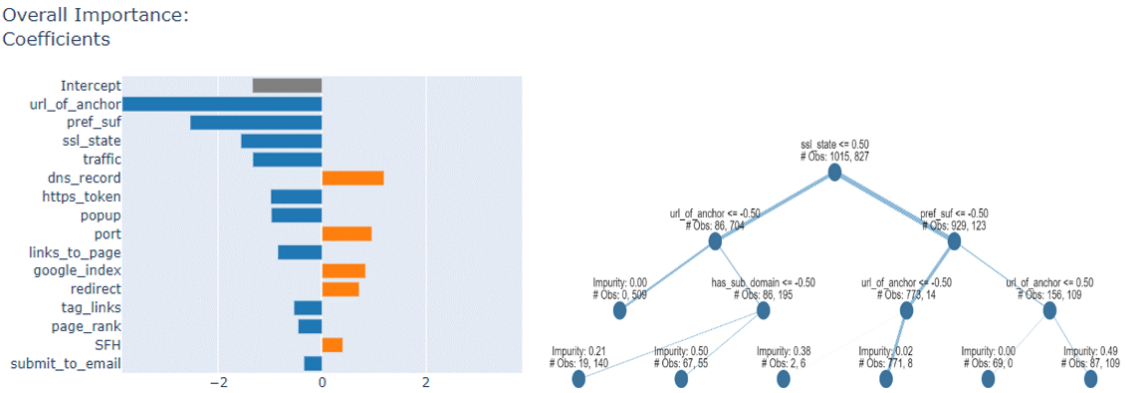

Figure 2: Overall Explanation of Training using (a) Logistic Regression (b) Decision Tree

Table 3: Summary of Predictions and Explanations

Figure No	Actual	Prediction by LR	Prediction By DT
Figure 3	Phishing	Normal	Normal
Figure 4	Normal	Phishing	Phishing
Figure 5	Normal	Normal	Normal
Figure 6	Phishing	Phishing	Phishing
Figure 7	Phishing	Normal	Phishing
Figure 8	Normal	Phishing	Normal
Figure 9	Phishing	Phishing	Normal
Figure 10	Normal	Phishing	Normal

decision-making visualization of decision trees. The tree's height is a hyperparameter that has been kept as 3 for the executions done in this work. Each node on the tree has two labels, one of them is the pair of observations representing number of instances of class 0 (Normal) and 1 (Phishing) respectively that satisfy the feature value conditions till that node. The second value is impurity value which varies in range of 0-1. Higher value of impurity means that the labels at this point are not homogenous. A good DT classifier should have lower values of impurity at each node. DT considers legitimate SSL, similar domain of anchor tags, presence of prefix and suffix, presence of subdomains in actual name of the website as the main deciding factors for distinguishing normal vs phishing URLs.

Each and every prediction made by the classifier can be explained in the glass box models. However, for demonstration purposes few cases have been explained here. Figures [3-10] explain the prediction logic used by each of the classifiers to give a particular outcome as prediction for the chosen test samples. In all the figures, left portion of the Figure shows the decision criteria used by logistic regression tree while the right side shows the orange colored path followed by decision tree to reach the outcome prediction. Left path is for zero (Normal) classification and right leaf nodes are one(phishing) classification. In Table 3, the summaries of labels of test instances for which explanations are generated are given. It has been taken care that all combinations are considered for evaluation.

Figure 3 shows the prediction explanation of a sample where the actual URL was a phishing URL but was predicted as normal by both classifiers due to high value of negative coefficient SSL state and low values of positive coefficients. DT shows the low value of number of anchor tags with different URLs as a distinguishing factor. In Figure 4, wrong predictions are made. This has happened as the case is already a boundary case due to actual probability of falling into normal category very low. Thus, this is the case of a well-crafted URL for phishing.

The higher values of negative coefficients in the URL of anchors is clearly one-sided to correctly classify the instance in Figure 5. Decision tree also makes a clear distinction with impurity of decision-making node being very less. In Figure 6, positively contributing features URLs of anchor and prefix / suffix have low values and thus the samples are correctly classified as Phishing. DT here has made use of another feature SSL state also. Figure 7 hows a case where DT performs correctly while the LR not. High values of negative coefficients of SSL State has led to decision of "normal" by the LR, while this is the case where DT detected the URL correctly just incidentally as the impurity level at decision node is quite high. As shown in Figure 8, LR again detected this URL as phishing due to low coefficient values of positively contributing feature – presence of prefix and suffix as well as SSL state. This has eliminated the effect of other positive coefficients like presence of DNS record. In this case, also DT gave correct answer just by chance. For the sample features tested in Figure 9, the phishing website is correctly

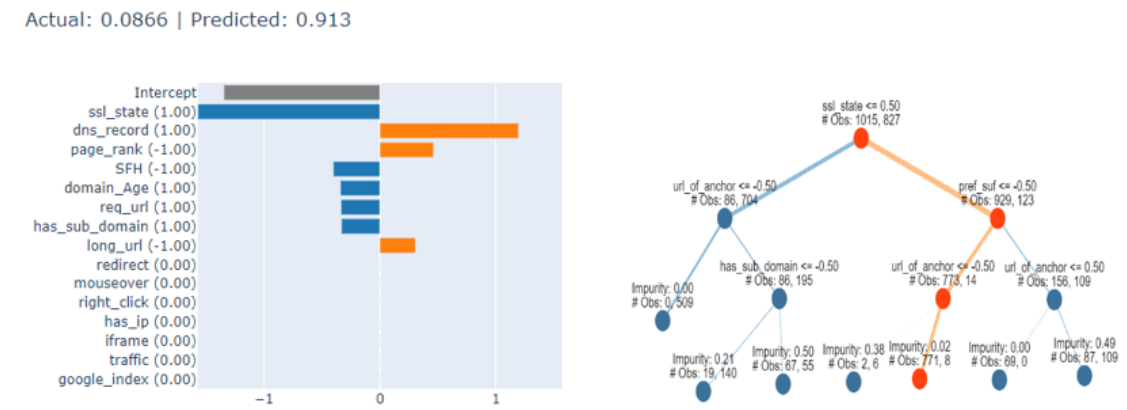

Figure 3: Explanation of a Sample where Actual = "Phishing", Predicted = "Normal" By Both Classifiers

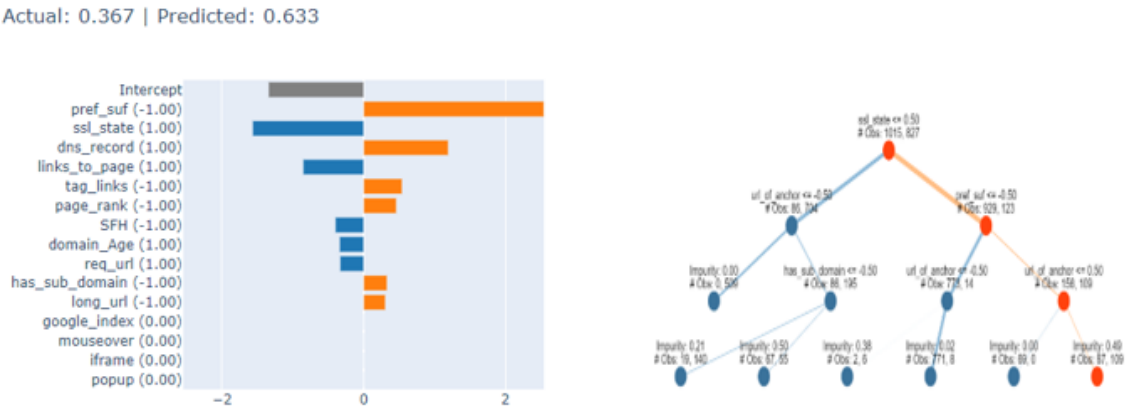

Figure 4: Explanation of Sample Actual = "Normal", Predicted = "Phishing" By Both Classifiers

identified by the coefficients of LR while the DT makes incorrect classification in a highly impure node. In Figure 10, the case where the LR makes incorrect decision due to high values of negative coefficients like URL of anchor and prefix/suffix presence. The decision made by DT is also purely incidental. Thus, this can be considered a case which may not have been well represented in the training examples.

5 CONCLUSIONS AND FUTURE WORKS

Phishing URLs are one of the most common types of attacks in cyberspace. Thus, their detection is of paramount importance to save individual users and networks from further escalations. Machine learning enhanced with XAI can help to detect new phishing techniques that may not be recognized by traditional systems. Overall, XAI can help to improve the effectiveness and accuracy of phishing URL detection systems and provide greater transparency and trust for users. The explanations at local level are very useful in generating counterfactual thoughts. The reported work can be extended to generate counterfactuals for phishing URLs so that legitimate users can avoid getting their links caught as False Negatives. The scheme has to be designed in such a manner that it is not usable by miscreants for creating undetectable phishing URL.

REFERENCES

[1] Chiew, Kang Leng, Kelvin Sheng Chek Yong, and Choon Lin Tan. "A survey of phishing attacks: Their types, vectors and technical approaches." Expert Systems with Applications 106 (2018): 1-20.
[2] Alkhalil, Z., Hewage, C., Nawaf, L., & Khan, I. (2021). Phishing attacks: A recent comprehensive study and a new anatomy. Frontiers in Computer Science, 3, 563060.
[3] Wu, Che-Yu, Cheng-Chung Kuo, and Chu-Sing Yang. "A phishing detection system based on machine learning." 2019 International Conference on Intelligent Computing and its Emerging Applications (ICEA). IEEE, 2019.
[4] Linardatos, P., Papastefanopoulos, V., & Kotsiantis, S. (2020). Explainable AI: A review of machine learning interpretability methods. Entropy, 23(1), 18.
[5] Althobaiti, K., Meng, N., & Vaniea, K. (2021, May). I don't need an expert! making URL phishing features human comprehensible. In Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems (pp. 1-17).
[6] Feroz, M. N., & Mengel, S. (2015, June). Phishing URL detection using URL ranking. In 2015 ieee international congress on big data (pp. 635-638). IEEE.
[7] Jeeva, S. C., & Rajsingh, E. B. (2016). Intelligent phishing url detection using association rule mining. Human-centric Computing and Information Sciences, 6(1), 1-19.
[8] Parekh, S., Parikh, D., Kotak, S., & Sankhe, S. (2018, April). A new method for detection of phishing websites: URL detection. In 2018 Second international conference on inventive communication and computational technologies (ICICCT) (pp. 949-952). IEEE.

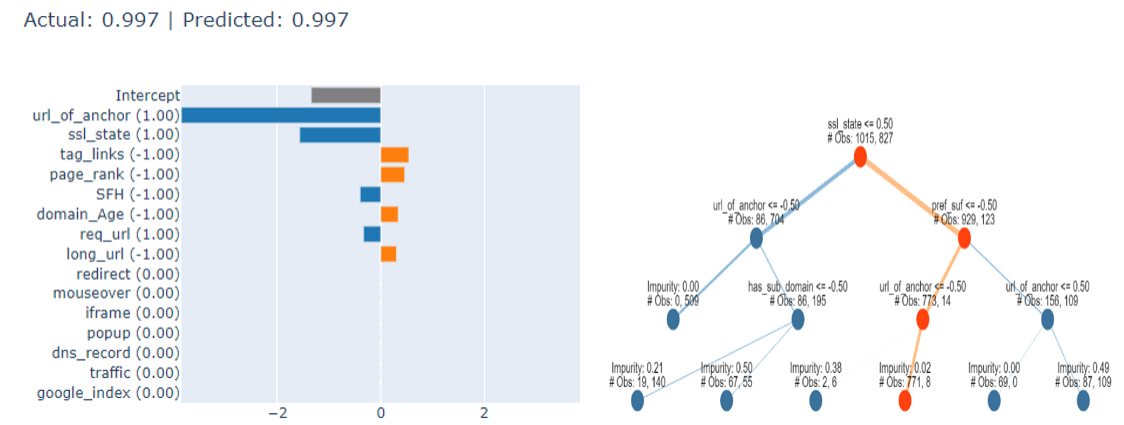

Figure 5: Explanation of Sample Actual = "Normal", Predicted = "Normal" By Both Classifiers

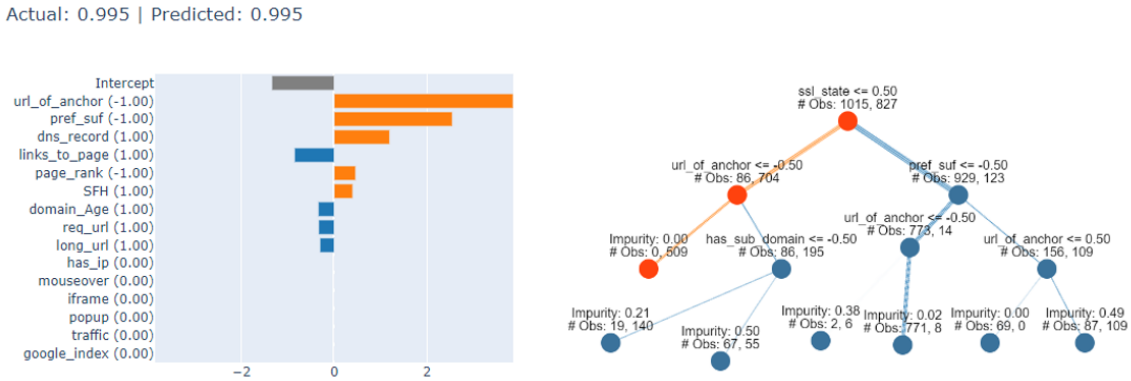

Figure 6: Explanation of Sample Actual = "Phishing" , Predicted = "Phishing" By Both Classifiers

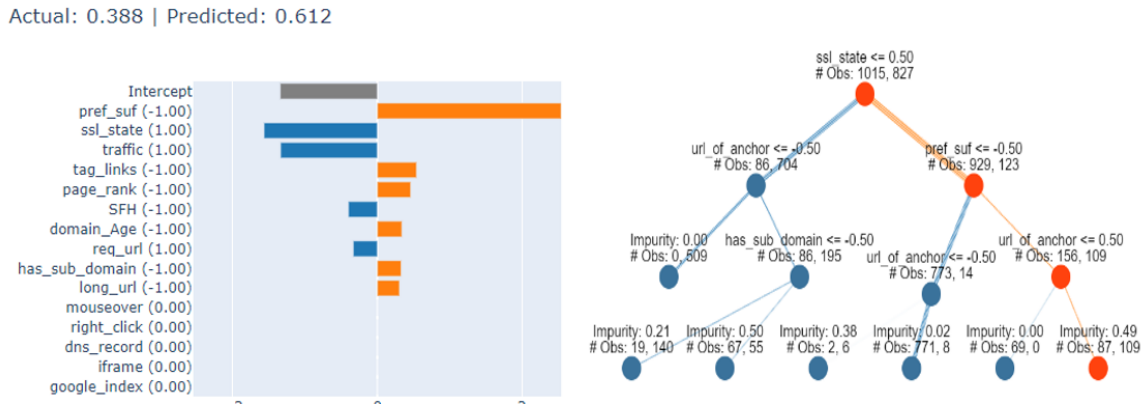

Figure 7: Explanation of Sample Actual = "Phishing" , L R→ "Normal" and DT → "Phishing"

[9] Adewole, K. S., Akintola, A. G., Salihu, S. A., Faruk, N., & Jimoh, R. G. (2019). Hybrid rule-based model for phishing URLs detection. In Emerging Technologies in Computing: Second International Conference, iCETiC 2019, London, UK, August 19–20, 2019, Proceedings 2 (pp. 119-135). Springer International Publishing.

[10] Hong, J., Kim, T., Liu, J., Park, N., & Kim, S. W. (2020). Phishing url detection with lexical features and blacklisted domains. Adaptive autonomous secure cyber systems, 253-267.

[11] Gupta, B. B., Yadav, K., Razzak, I., Psannis, K., Castiglione, A., & Chang, X. (2021). A novel approach for phishing URLs detection using lexical based machine learning in a real-time environment. Computer Communications, 175, 47-57.

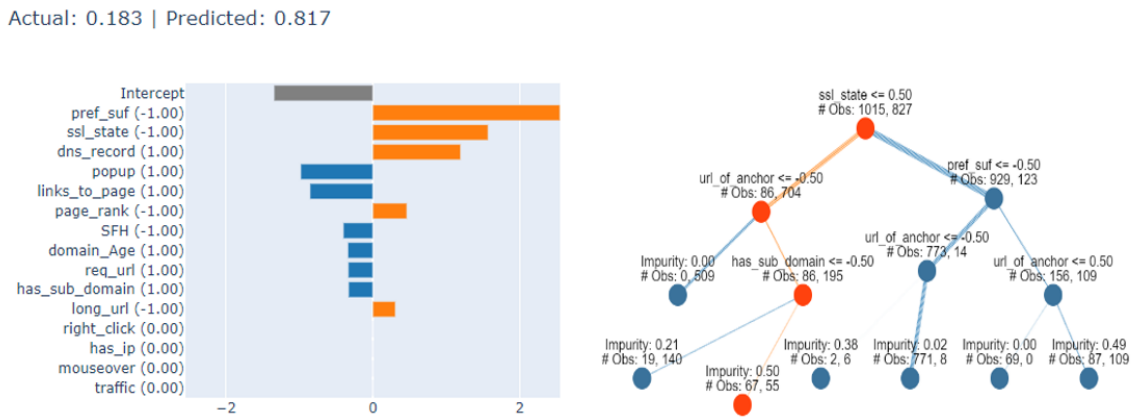

Figure 8: Explanation of Sample Actual = "Normal" , L R→ "Phishing" and DT → "Normal"

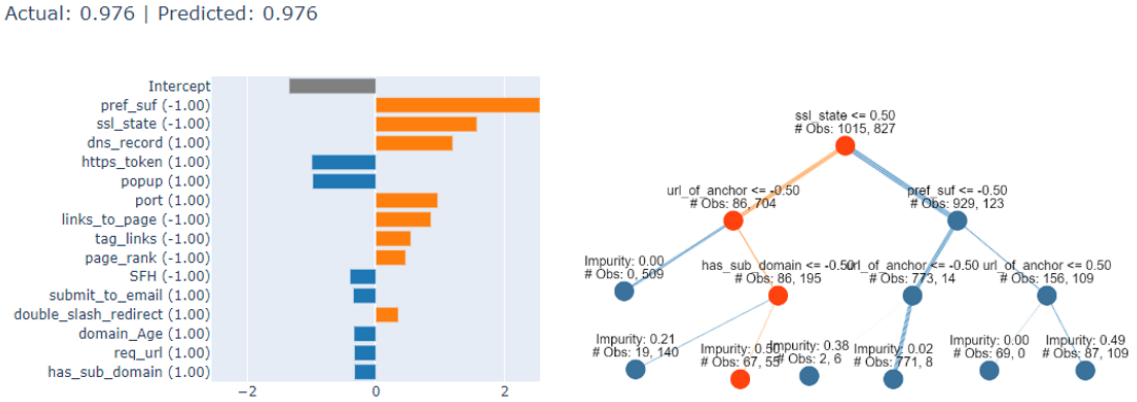

Figure 9: Explanation of Sample Actual = "Phishing", L R→ "Phishing" and DT → "Normal"

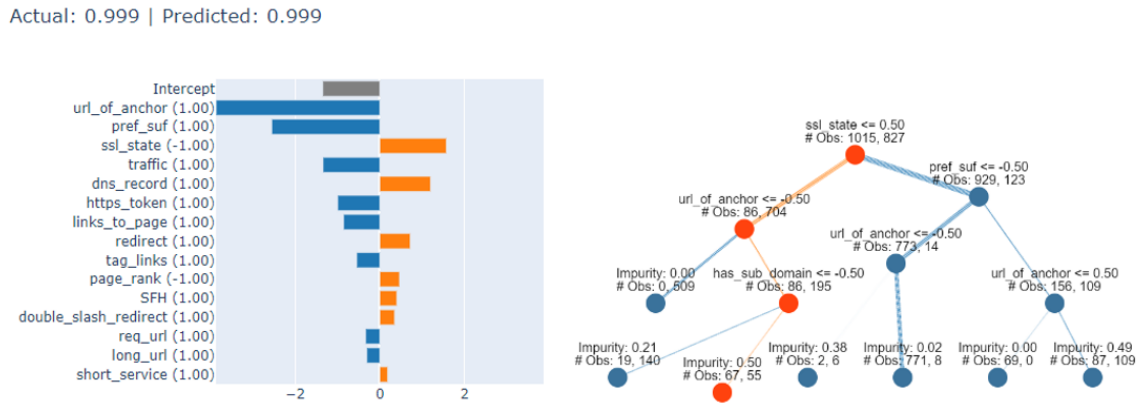

Figure 10: Explanation of Sample Actual = "Normal", L R→ "Phishing" and DT → "Normal"

[12] Ahammad, S. H., Kale, S. D., Upadhye, G. D., Pande, S. D., Babu, E. V., Dhumane, A. V., & Bahadur, M. D. K. J. (2022). Phishing URL detection using machine learning methods. Advances in Engineering Software, 173, 103288.

[13] Hernandes, P. R. G., Floret, C. P., De Almeida, K. F. C., Da Silva, V. C., Papa, J. P., & Da Costa, K. A. P. (2021, December). Phishing detection using url-based xai techniques. In 2021 IEEE Symposium Series on Computational Intelligence (SSCI) (pp. 01-06). IEEE.

[14] Poddar, S., Chowdhury, D., Dwivedi, A. D., & Mukkamala, R. R. (2022, December). Data Driven based Malicious URL Detection using Explainable AI. In 2022 IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom) (pp. 1266-1272). IEEE.

[15] Albakry, S., & Vaniea, K. (2018, July). Automatic Phishing Detection versus User Training, Is there a Middle Ground Using XAI?. In SICSA ReaLX.
[16] https://archive.ics.uci.edu/ml/machine-learning-databases/00327/ [Accessed on 12th May 2023]
[17] https://interpret.ml/ [Accessed on 12th May 2023]
[18] Rai, A. (2020). Explainable AI: From black box to glass box. Journal of the Academy of Marketing Science, 48, 137-14